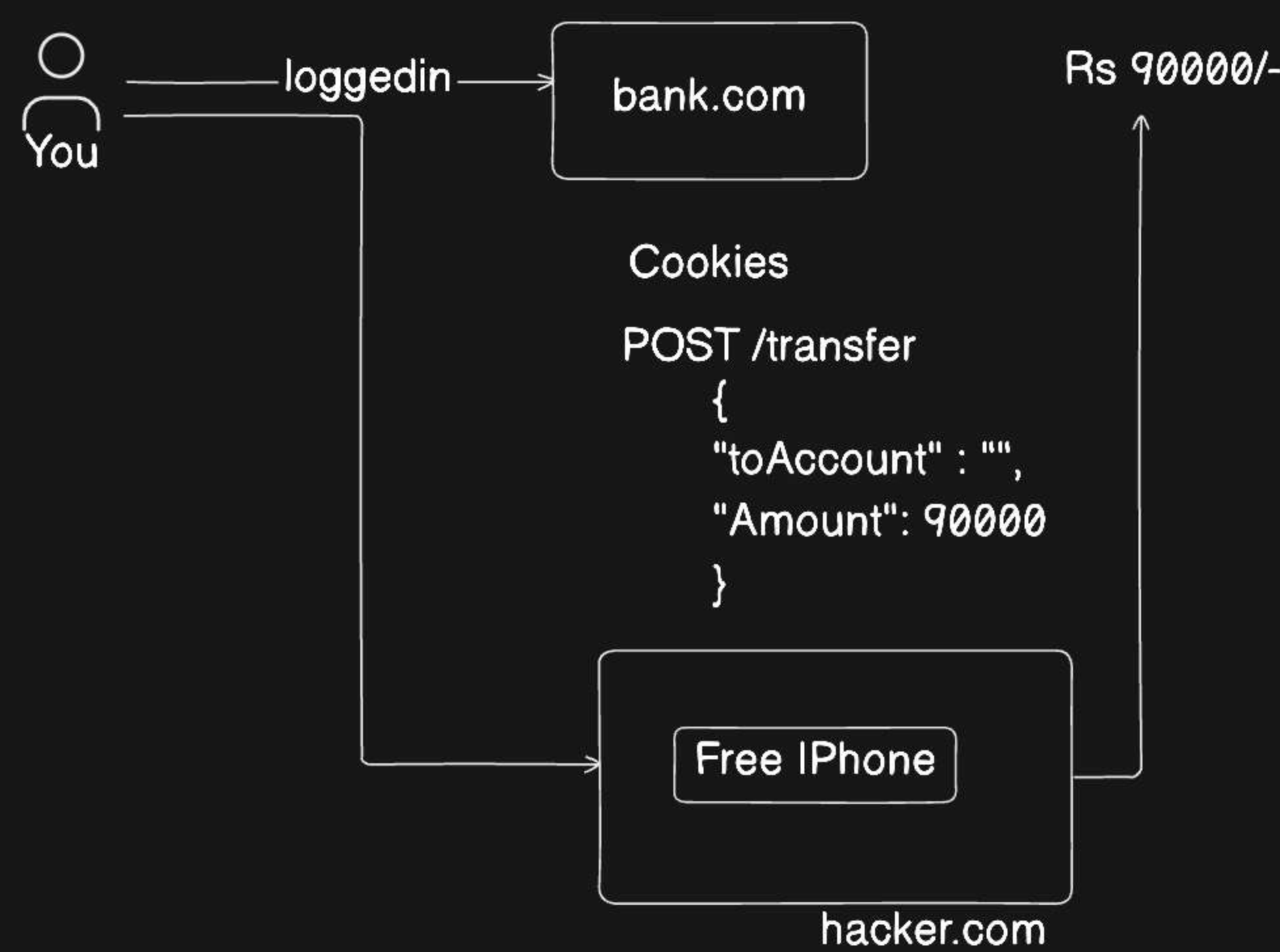


1. Cross-Site Request Forgery (CSRF)
2. Solution

Cross-Site Request Forgery (CSRF)

CSRF is a web vulnerability where an attacker tricks an authenticated user's web browser into executing an unwanted, state-changing action on a trusted website.



1. You loggedin to your bank.com
2. You some how reach to an hacker website
3. You did something in hacker website
4. Your bank cookie attached to your request made in hacker.com
5. Your money gone

Why CSRF is so dangerous?

1. Money Transfer
2. Password Change
3. Profile Detail Change
4. Social media unwanted activity
5. Delete/Update resource

Solution

1. CSRF Token
2. SameSite
3. Check Origin and Reffer

1. CSRF Token



2. SameSite

- None: Cookie can be used for both same and cross-site
- Strict: Cookie can be used for same site
- Lax: (Default) Cookie can be used for same site and some specific cross-site

http://localhost:2000	Same site
http://localhost:3000	

http://localhost:2000	Different site
http://127.0.0.1:3000	

https://google.com/abc	Same site
https://google.com/xyz	

https://google.com	Different site
https://facebook.com	

developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Set-Cookie#samesitesamesite-value

3. Check Origin and Reffer

```
if(req.header.orgin === "http://localhost:2000") {
  // Accept the request
} else {
  // Reject the request
}
```

XSS vs CSRF

- XSS: Attacker tries to insert malicious code into your website
- CSRF: Attacker tricks user to send unwanted request

CSRF Tokens can fail if XSS exist:
Hacker can inject some code which will expose CSRF token

XSS and CSRF should be fixed in your application

